RAPPORT DE TRAVAUX PRATIQUES : CYBERSÉCURITÉ

TP 3.2 — Attaque d’un système Windows et extraction d’identifiants

1. INTRODUCTION ET OBJECTIFS

Le but de ce TP est de simuler un scénario d'attaque réaliste en entreprise. Nous allons démontrer comment un attaquant, disposant déjà d'un accès au réseau local, peut compromettre un poste de travail Windows. L'accent est mis sur l'exploitation des **mauvaises configurations** et des **identifiants faibles** plutôt que sur des vulnérabilités logicielles complexes.

2. CONTEXTE DU LABORATOIRE

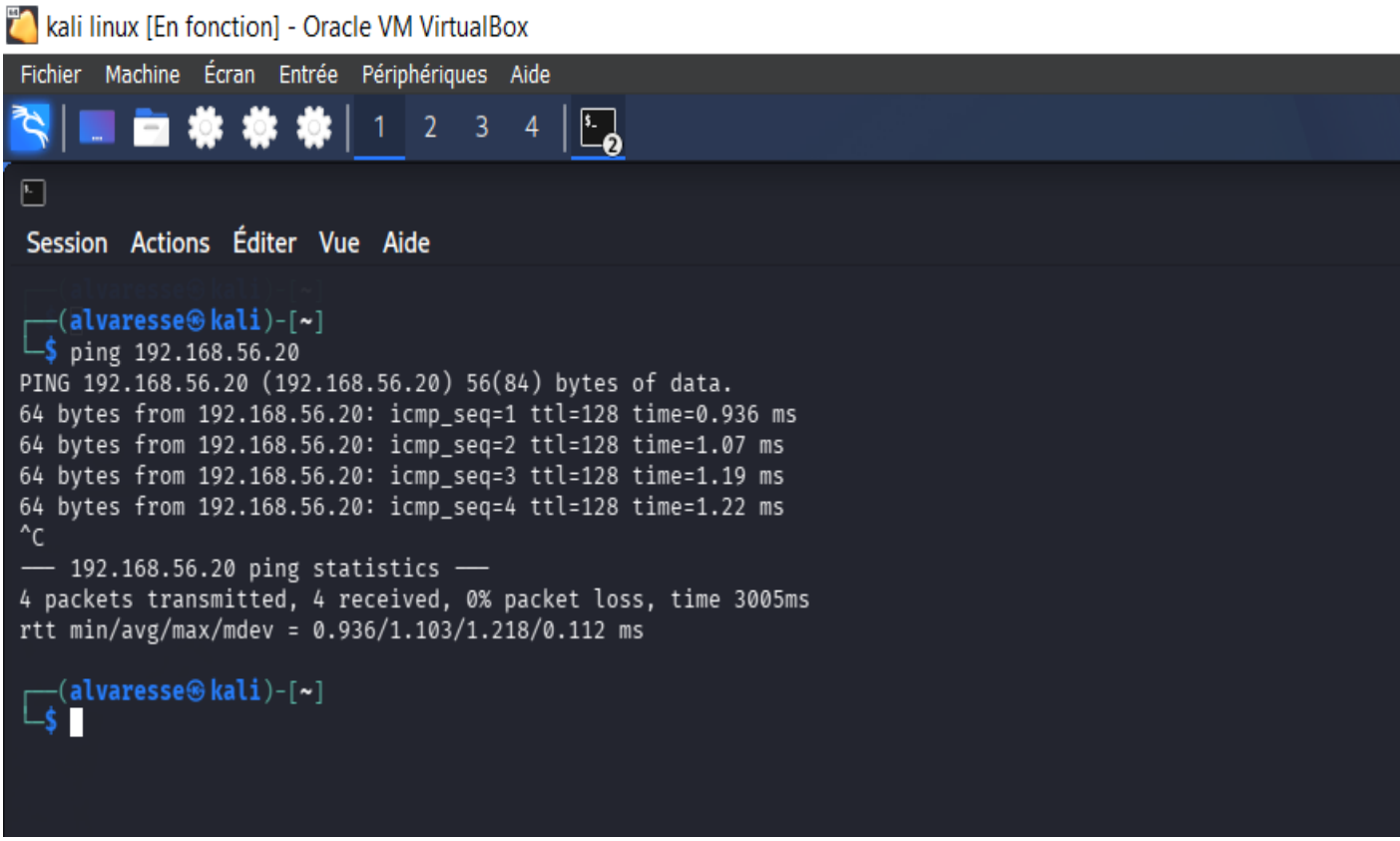
- **Machine Attaquante :** Kali Linux (`192.168.56.30`)
- **Machine Cible :** Windows (`192.168.56.20`)
- **Scénario :** NetSecure

---

3. DEROULEMENT DE L'ATTAQUE

3.1. Vérification de l'accessibilité

Avant toute tentative d'intrusion, nous vérifions que la cible est joignable via la commande `ping`.



PING RÉUSSI

3.2. Identification des services exposés

Nous utilisons l'outil **Nmap** pour scanner les ports ouverts sur la cible.

Commande : nmap -sS 192.168.56.20

kali linux [En fonction] - Oracle VM VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

1 2 3 4

Session Actions Éditer Vue Aide

```
┌──(alvaresse㉿kali)-[~]
└─$ nmap -SS 192.168.56.20
Failed to resolve/decode supposed IPv4 source address "S": Temporary failure in name resolution
QUITTING!

┌──(alvaresse㉿kali)-[~]
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 00:45 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00080s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
554/tcp   open  rtsp
2869/tcp  open  icslap
10243/tcp open  unknown
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:F5:60:8D (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.96 seconds
```

SCAN NMAP (PORT 445 SMB)]

Analyse : Le port **445 (SMB)** est ouvert, ce qui indique que le partage de fichiers est actif et constitue une surface d'attaque potentielle.

3.3. Récupération d'informations sans authentification

Nous tentons d'obtenir des détails sur le système d'exploitation sans posséder de compte.

- **Commande :** nmap -p 445 --script smb-os-discovery 192.168.56.20

kali linux [En fonction] - Oracle VM VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

1 2 3 4

Session Actions Éditer Vue Aide

```
┌──(alvaresse㉿kali)-[~]
└─$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 00:48 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00099s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:F5:60:8D (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: HP-WORSTATION
|   NetBIOS computer name: HP-WORSTATION\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-27T23:48:31-07:00

Nmap done: 1 IP address (1 host up) scanned in 5.08 seconds

┌──(alvaresse㉿kali)-[~]
└─$
```

INFORMATIONS OS RÉCUPÉRÉES

3.4. Découverte des partages réseau

Nous listons les partages disponibles pour voir si certains sont accessibles de manière anonyme.

- **Commande :** smbclient -L //192.168.56.20 -N

kali linux [En fonction] - Oracle VM VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

1 2 3 4

Session Actions Éditer Vue Aide

```
┌──(alvaresse㉿kali)-[~]
└─$ smbclient -L //192.168.56.20 -N

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        TOP_SECRET      Disk
        Users           Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

┌──(alvaresse㉿kali)-[~]
└─$
```

LA LISTE DES PARTAGES SMB

```
┌──(alvaresse㉿kali)-[~]
└─$ smbclient //192.168.56.20/TOP_SECRET -N
Try "help" to get a list of possible commands.
smb: \> get TOP_SECRET
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \TOP_SECRET
smb: \> get TOP_SECRET
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \TOP_SECRET
smb: \> ls
NT_STATUS_ACCESS_DENIED listing \*
smb: \>
```

4. EXPLOITATION ET COMPROMISSION

4.1. Test de connexion avec Metasploit

Suite à la création d'un compte vulnérable (`testuser` / `Password123!`), nous utilisons le module `smb_login` de Metasploit pour tester la validité des identifiants.

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier  Machine  Écran  Entrée  Périphériques  Aide
1  2  3  4
alvaresse@kali: ~
Session  Actions  Éditer  Vue  Aide

┌──(alvaresse㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session

IIIIIII    dTb.dTb        _.---._
  II      4'  v  'B    .'"".'/|\`.""'.
  II      6.     .P  :  .' / | \  `.  :
  II      'Ti.  .;P'  '.'  /  |  \`.'
  II       'T; ;P'     `. /   |   \ .'
IIIIIII     'YvP'        `-._|_.-'

I love shells --egypt


       =[ metasploit v6.4.116-dev                         ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads     ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass password123!
SMBPass => password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445     - 192.168.56.20:445     - Starting SMB login bruteforce
[+] 192.168.56.20:445     - 192.168.56.20:445     - Success: '.\testuser:password123!'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445     - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

SUCCÈS D'AUTHENTIFICATION SUR METASPLOIT

4.2. Ouverture d'une session distante (Meterpreter)

Une fois les identifiants validés, nous utilisons l'exploit `psexec` pour obtenir un accès total.

- **Payload utilisé :** `exploit/windows/smb/psexec`

4.3. Extraction des informations sensibles (Hashdump)

Après avoir élevé nos privilèges avec `getsystem`, nous extrayons les empreintes (hashes) des mots de passe du système.

5. ANALYSE ET RECOMMANDATIONS

5.1. Causes de la compromission

La réussite de cette attaque repose sur deux erreurs majeures de configuration :

1. **Faiblesse des identifiants :** L'utilisation d'un mot de passe simple a permis une authentification immédiate via SMB.
2. **Exposition du service SMB :** Le service était accessible et permettait l'énumération d'informations à distance.

5.2. Mesures de remédiation

Pour empêcher ce scénario, je préconise les mesures suivantes :

- **Politique de mots de passe stricte :** Imposer une complexité minimale et un changement régulier.
- **Désactivation des services inutiles :** Désactiver SMB si le partage de fichiers n'est pas requis.
- **Filtrage réseau :** Utiliser un pare-feu pour limiter l'accès au port 445 aux seules machines autorisées.

---

6. CONCLUSION

Ce TP démontre qu'une attaque n'a pas besoin d'être techniquement sophistiquée pour réussir. Une simple erreur humaine ou une mauvaise hygiène informatique suffit à compromettre l'intégralité d'un système Windows. L'utilisation d'outils comme **Nmap** pour l'audit et **Metasploit** pour la preuve de concept est essentielle pour identifier ces failles avant qu'un attaquant réel ne les exploite.